

Table of Contents

Phase 0 – Scope Verification	1
Phase 1 – Passive Information Gathering	5
Phase 2 – Active Information Gathering	17
Phase 3 – Analysis & Attack Surface Mapping	20
Conclusion:	23

List of Figures:

Figure 1: Shopify CDN	2
Figure 2: Shopify Changelog.....	3
Figure 3: Shopify Hardware.....	4
Figure 4: WHOIS Shopify.com.....	5
Figure 5: DNS and Subdomain enumeration.....	6
Figure 6: Shopify.com/robots.txt.....	7
Figure 7: Shopify.com/sitemap.xml.....	8
Figure 8: Shopify Fingerprinting	9
Figure 9: Shopify MIME types	10
Figure 10: Shopify URL Captures.....	11
Figure 11: Shopify Harvesting	12
Figure 12: Site: Shopify.com	13
Figure 13: Site: Shopify.com filetype:pdf	14
Figure 14: Site: Shopify.com intitle:about	15
Figure 15: Site: *.Shopify.com	16
Figure 16: Host Discovery	17
Figure 17: Port Scanning.....	17
Figure 18: Service Detection	18
Figure 19: OS System Detection	18
Figure 20: WAF Detection	19
Figure 21: DNS Transfer Attempt	19
Figure 22: Finding Ip Address of domain and Shopify Subdomain sites	20
Figure 23: Port Scanning in the target IP Address.....	21

Information Gathering & Reconnaissance Assignment

Objective:

This report demonstrated the systematic and moral reconnaissance carried out against a legally permissible public Vulnerability Disclosure Program hosted on Hacker One. The Shopify program run by Shopify is the chosen target.

The only methods of reconnaissance that were allowed within the scope were used. Prioritizing passive data collection was followed, when permitted, by limited active scanning. There was no use of brute force or vulnerability scanning techniques.

The Objective of this assignment was to identify the attack surface and assess potential security risks without performing any intrusive or invasive actions.

Phase 0 – Scope Verification

a) Select ONE public VDP/Bug Bounty program (HackerOne, Bugcrowd, or Intigriti).

- The Selected public platform for this VDP or Bug bounty target assignment is Shopify e-commerce platform for all business which operates its security disclosure program through HackerOne

b) Include the program URL and copy the exact in-scope section in your report.

- HackerOne (2026) Shopify. Available at: <https://hackerone.com/shopify> (Accessed: 4 March 2026).

c) List in-scope assets and explicitly mention out-of-scope assets.

- *.shopify.com: The *.shopify.com search in the google shows all includes subdomain under shopify.com. For Example, help.shopify.com, cdn.shopify.com, changelog.shopify.com and hardware

i. [Help.shopify.com/shopify-admin](https://help.shopify.com/shopify-admin):



Shopify admin

Your Shopify admin is the central hub for managing all aspects of your store. The admin is a back-office tool for running your business' operations and logistics, as well as implementing your online design and marketing. It provides access to all the tools and features you need to run your business, including processing orders, managing products, analyzing sales data, and configuring store settings.

ii. cdn.shopify.com:



Shopify CDN

Shopify CDN refers to the content delivery Network used by shopify to delivery content fast and dynamic file transformation to users around the world.

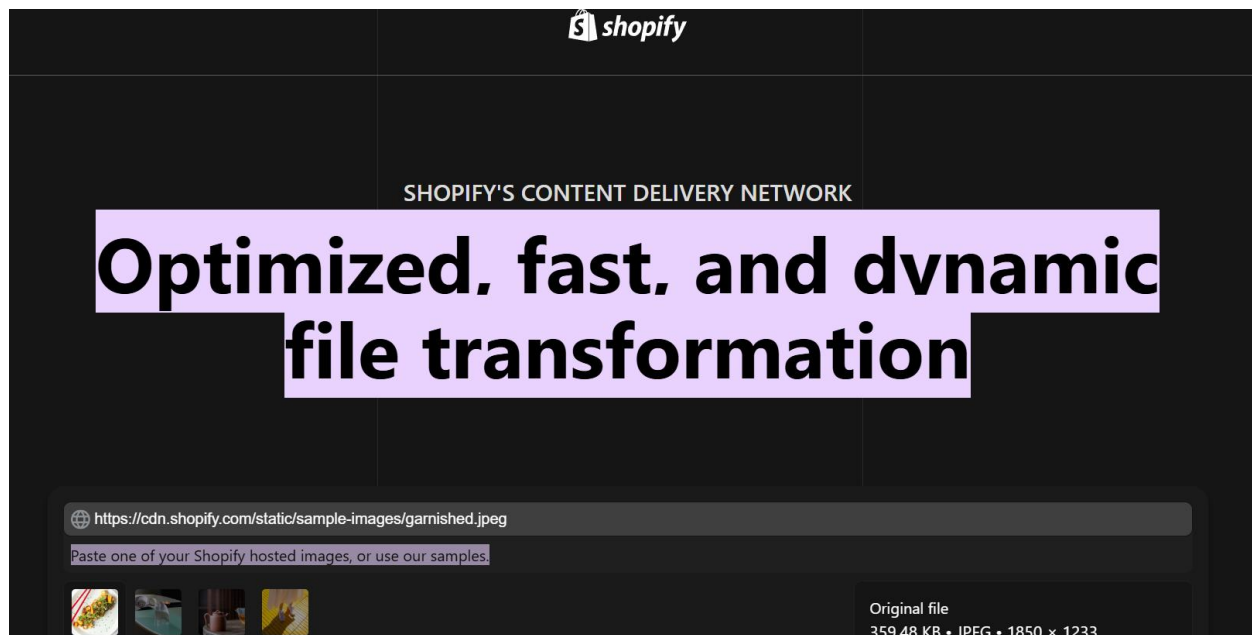


Figure 1: Shopify CDN

iii. changelog.shopify.com:



Shopify changelog is a record of updates, improvements and fixes made to shopify's ecommerce platform, API and developer tools. The following changelog.shopify.com subdomain shows all the updates with time made by the shopify platform including sectors like Admin, Analytics, Apps, B2B, Marketing etc.

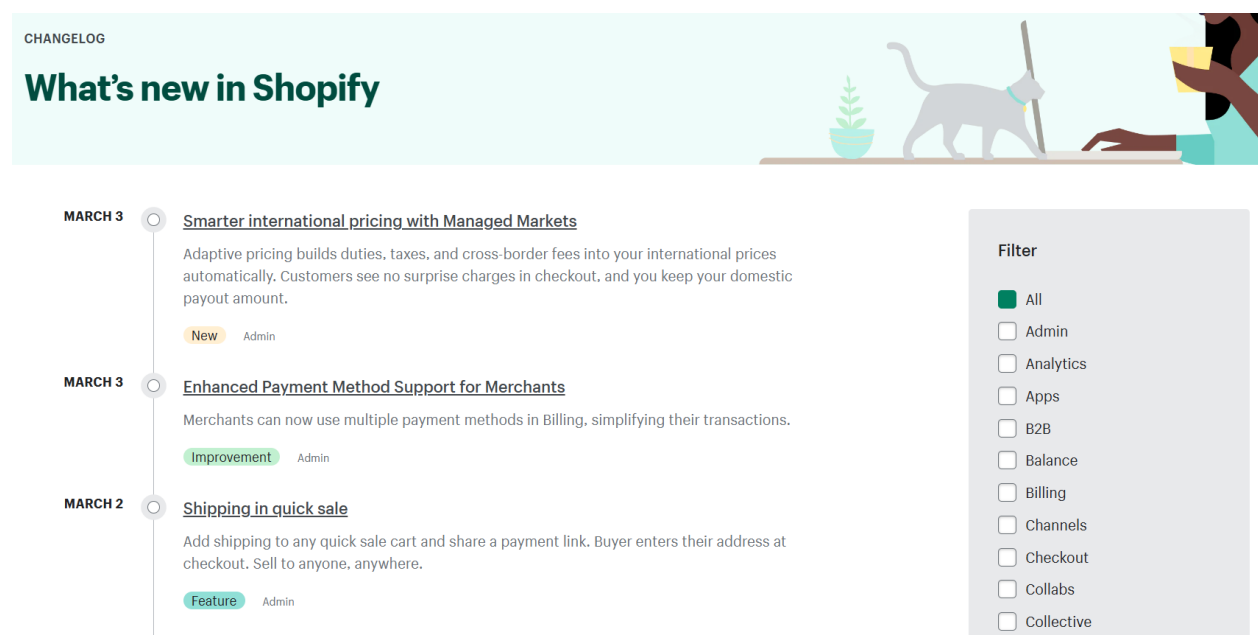


Figure 2: Shopify Changelog

iv. hardware.shopify.com



Shopify Hardware Store: Point of Sale Hardware - Shopify ...

Shopify hardware subdomain is a store that includes every POS hardware that you need for your retail store to accept cash and credit cards and to print receipts. Includes free shipping and a 30 days trials.

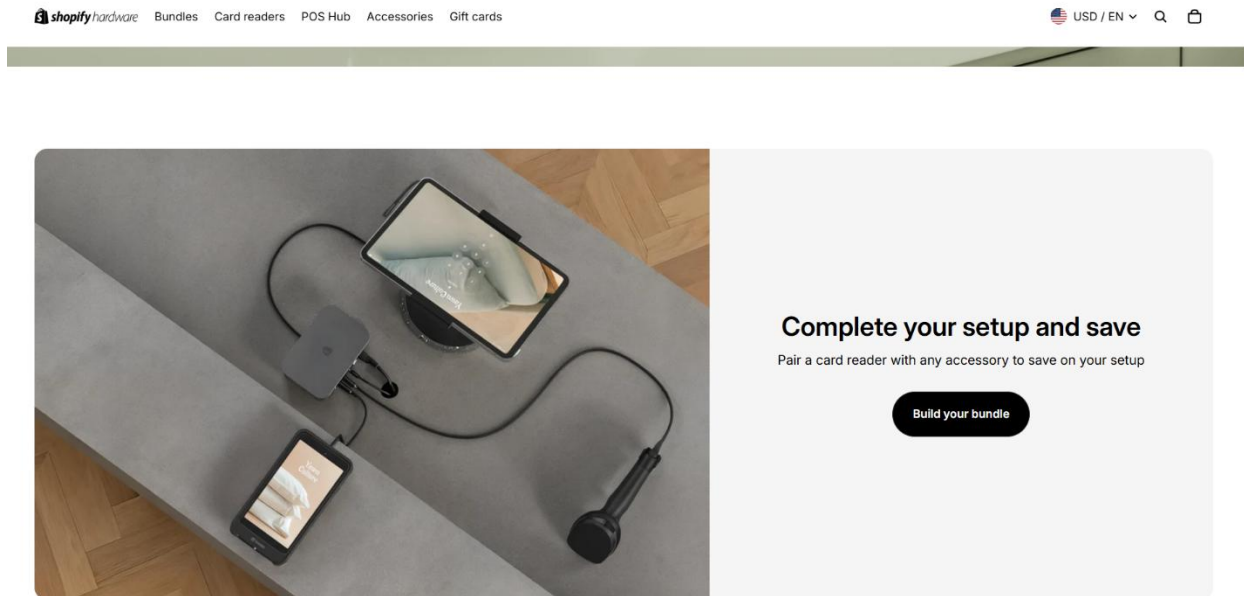


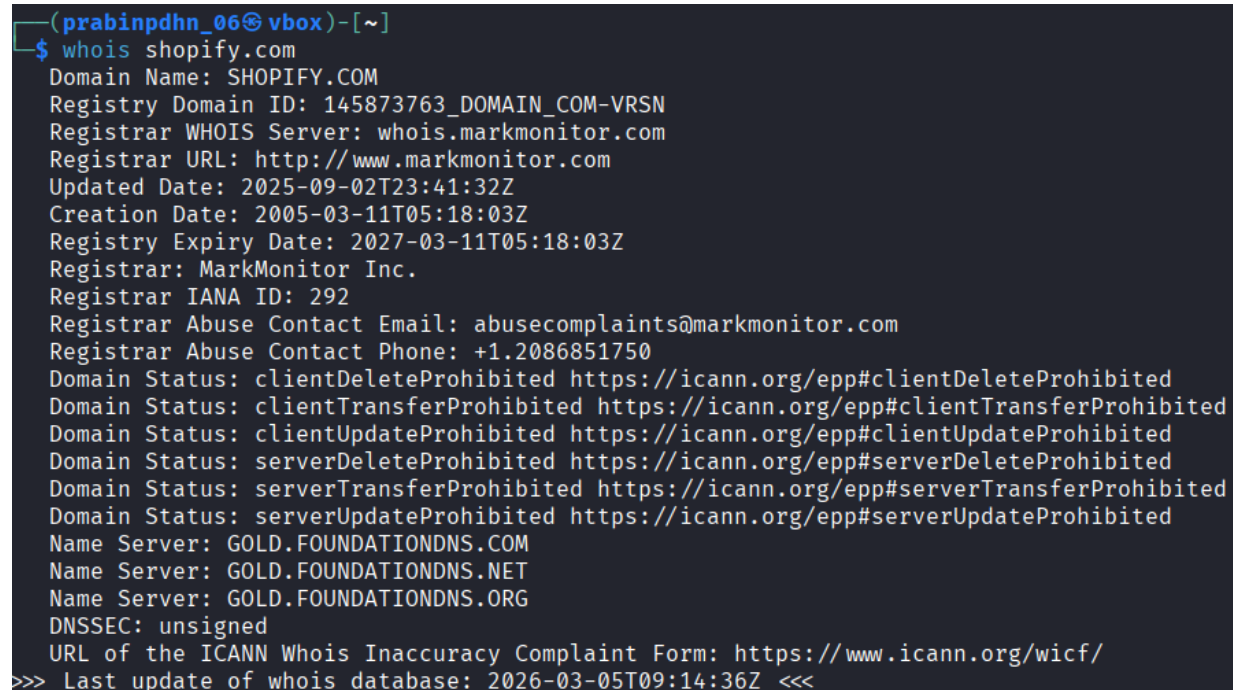
Figure 3: Shopify Hardware

d) Choose ONE domain strictly within scope.

- The domain shopify.com was selected for reconnaissance because it is explicitly listed as an in-scope asset in the bug bounty program hosted on HackerOne for Shopify.

Phase 1 – Passive Information Gathering

a) WHOIS (domain and IP if resolved).



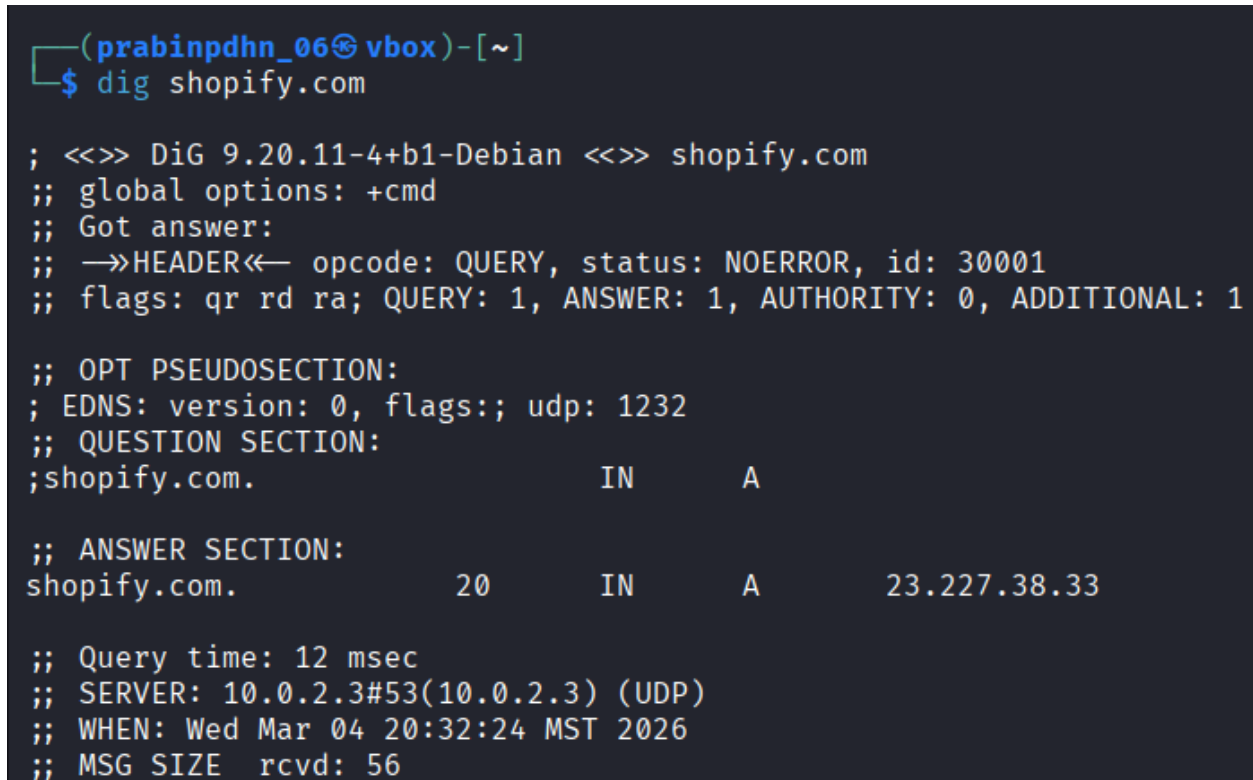
```
(prabindhn_06@vbox)-[~]
$ whois shopify.com
Domain Name: SHOPIFY.COM
Registry Domain ID: 145873763_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.markmonitor.com
Registrar URL: http://www.markmonitor.com
Updated Date: 2025-09-02T23:41:32Z
Creation Date: 2005-03-11T05:18:03Z
Registry Expiry Date: 2027-03-11T05:18:03Z
Registrar: MarkMonitor Inc.
Registrar IANA ID: 292
Registrar Abuse Contact Email: abusecomplaints@markmonitor.com
Registrar Abuse Contact Phone: +1.2086851750
Domain Status: clientDeleteProhibited https://icann.org/epp#clientDeleteProhibited
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Domain Status: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited
Domain Status: serverDeleteProhibited https://icann.org/epp#serverDeleteProhibited
Domain Status: serverTransferProhibited https://icann.org/epp#serverTransferProhibited
Domain Status: serverUpdateProhibited https://icann.org/epp#serverUpdateProhibited
Name Server: GOLD.FOUNDATIONDNS.COM
Name Server: GOLD.FOUNDATIONDNS.NET
Name Server: GOLD.FOUNDATIONDNS.ORG
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-03-05T09:14:36Z <<<
```

Figure 4: WHOIS Shopify.com

The domain registration information for shopify.com is collected by using a whois query, as shown in the given Screenshots. From the obtained information we can identify domain ownership and infrastructure details.

- i. Domain Name: SHOPIFY.COM
- ii. Registry Domain ID: 145873763_DOMAIN_COM-VRSN
- iii. Registration Date: 2005-03-11T05:18:03Z
- iv. Registration Expiry Date: 2027-03-11T05:18:03Z
- v. Register URL: www.markmonitor.com
- vi. Server Name: GOLD.FOUNDATIONDNS.COM
GOLD.FOUNDATIONDNS.NET
GOLD.FOUNDATIONDNS.ORG

b) DNS and passive subdomain enumeration.



```
(prabindhn_06@vbox)-[~]
$ dig shopify.com

; <<>> DiG 9.20.11-4+b1-Debian <<>> shopify.com
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 30001
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
;; QUESTION SECTION:
;shopify.com.                IN      A

;; ANSWER SECTION:
shopify.com.                20      IN      A      23.227.38.33

;; Query time: 12 msec
;; SERVER: 10.0.2.3#53(10.0.2.3) (UDP)
;; WHEN: Wed Mar 04 20:32:24 MST 2026
;; MSG SIZE rcvd: 56
```

Figure 5: DNS and Subdomain enumeration

The DNS records were checked using dig command to identify domain infrastructure. DNS enumeration reveals how the domain is hosted and structured. From the obtained information we identify IP address, DNS records and Server IP.

i. IP Address: 23.227.38.33

ii. DNS Record: A Type

iii. Server IP: 10.0.2.3

c) robots.txt and sitemap analysis.

```

# robots.txt file for www.shopify.com
User-agent: GoogleDocs
Disallow: /

User-agent: AdIdxBot
Allow: */ppc/*
Allow: *utm_medium=cpc*

User-agent: Pinterestbot
Allow: */ppc/*
Allow: *utm_medium=cpc*

User-agent: AdsBot-Google-Mobile
Allow: */ppc/*
Allow: *utm_medium=cpc*

User-agent: AdsBot-Google
Allow: */ppc/*
Allow: *utm_medium=cpc*

User-agent: *
Disallow: *.data$
Disallow: */account
Disallow: */auth/callback
Disallow: */authenticate
Disallow: */authentication
Disallow: */editor$
Disallow: */finalize$
Disallow: */loading$
Disallow: */onboarding$
Disallow: */ppc/*
Disallow: */result$
Disallow: */services/identity/login
Disallow: */services/sa-appointments/login
Disallow: */services/sa-appointments/redirect
Disallow: */stock-photos/*?*page=*?*page=*
Disallow: */stock-photos/*?link_search=
Disallow: */stock-photos/*?q=
Disallow: */stock-photos/@*
Disallow: */stock-photos/admin
Disallow: */stock-photos/photos/search$
Disallow: */stock-photos/photos/search?
Disallow: */store/account
Disallow: */store/admin
Disallow: */store/cart
Disallow: */store/carts
Disallow: */store/checkout
Disallow: */store/checkouts/
Disallow: */store/orders
Disallow: */tools/*/show*
Disallow: /*?flags=*
Disallow: *country=*

Disallow: *itcat=*
Disallow: *itterm=*
Disallow: *lang=*
Disallow: *link_search=*
Disallow: *page=*
Disallow: *prev_msid=*
Disallow: *utm_medium=cpc*
Disallow: /*/*?*shpxid=*
Disallow: /*/*?services*
Disallow: /*/*digital_wallets/dialog
Disallow: /*/admin/
Disallow: /*/apple-app-site-association
Disallow: /*/blog-article-remove-faq-utms-*.js
Disallow: /*/blog.atom
Disallow: /*/blog/search$
Disallow: /*/blog/search?
Disallow: /*/blogs/blog.atom
Disallow: /*/blogs/technology.atom
Disallow: /*/blogsearch$
Disallow: /*/cannabis
Disallow: /*/cdn-cgi/challenge-platform*
Disallow: /*/email-validation
Disallow: /*/enterprise/blog/search$
Disallow: /*/enterprise/blog/search?
Disallow: /*/growth-tools-assets
Disallow: /*/landing/
Disallow: /*/retail/search$
Disallow: /*/retail/search?
Disallow: /*/step/
Disallow: /*/submit
Disallow: /*/submitted
Disallow: /*/technology.atom
Disallow: /*/technology/tagged/*page*
Disallow: /*/tools/business-name-generator/searchbutton*
Disallow: /*/tools/business-name-generator/searchpage*
Disallow: /*/tools/business-name-generator/searchutf8*
Disallow: /*/ventureone
Disallow: /*CampaignId*
Disallow: /*hashid=%subscriber_hash%
Disallow: /*hubs_content*
Disallow: /.s/assets/shopifycloud/collabs-community-widge
Disallow: /.well-known/traffic-advice
Disallow: /500
Disallow: /__dux
Disallow: /__manifest
Disallow: /__pb/mm
Disallow: /__pb/rp
Disallow: /__pb/rr
Disallow: /authenticate
Disallow: /blog-article-remove-faq-utms-*.js
Disallow: /blog/search$
Disallow: /blog/search?

```

Figure 6: Shopify.com/robots.txt

The www.shopify.com/robots.txt is a plain text file located in the root of a shopify website. It tells search engine crawlers and other automated bots which parts of site they are allowed or disallowed to access. From this file we can identify restricted directories sensitive and internal pages.

This XML file does not appear to have any style information associated with it. The document tree is shown below.

```
<?xmlset xmlns="http://www.sitemaps.org/schemas/sitemap/0.9" xmlns:xhtml="http://www.w3.org/1999/xhtml" xmlns:video="http://www.google.com/schemas/sitemap-video/1.1">
  <url>
    <loc>https://www.shopify.com/</loc>
    <lastmod>2026-03-05</lastmod>
    <changefreq>daily</changefreq>
    <priority>1.0</priority>
  </url>
  <url>
    <loc>https://www.shopify.com/1mbb</loc>
    <lastmod>2026-03-05</lastmod>
    <changefreq>daily</changefreq>
    <priority>0.8</priority>
  </url>
  <url>
    <loc>https://www.shopify.com/404-static</loc>
    <lastmod>2026-03-05</lastmod>
    <changefreq>daily</changefreq>
    <priority>0.8</priority>
  </url>
  <url>
    <loc>https://www.shopify.com/about</loc>
    <lastmod>2026-03-05</lastmod>
    <changefreq>daily</changefreq>
    <priority>0.8</priority>
  </url>
  <url>
    <loc>https://www.shopify.com/accessibility</loc>
    <lastmod>2026-03-05</lastmod>
    <changefreq>daily</changefreq>
    <priority>0.8</priority>
  </url>
  <url>
    <loc>https://www.shopify.com/accessibility/plan</loc>
    <lastmod>2026-03-05</lastmod>
    <changefreq>daily</changefreq>
    <priority>0.8</priority>
  </url>
  <url>
    <loc>https://www.shopify.com/accessibility/policy</loc>
    <lastmod>2026-03-05</lastmod>
    <changefreq>daily</changefreq>
    <priority>0.8</priority>
  </url>
  <url>
    <loc>https://www.shopify.com/accessibility/vpat-admin</loc>
    <lastmod>2026-03-05</lastmod>
    <changefreq>daily</changefreq>
    <priority>0.8</priority>
  </url>
```

Figure 7: Shopify.com/sitemap.xml

The www.shopify.com/sitemap.xml is a list all URLs of shopify websites that should be indexed by search engines. It reveals the structure of a site, hidden pages or unlinked content that could be targets for testing or any web attack. From the obtained file information, we can identity different URL of shopify such as about page, accessibility page, product page, amazon pay etc.

d) Technology fingerprinting (Wappalyzer / WhatWeb).

```

(prabindhn_06@vbox)-[~]
$ whatweb shopify.com
http://shopify.com [301 Moved Permanently] Country[CANADA][CA], HTTPServer[cloudflare], IP[23.227.38.33], RedirectLocation[https://www.shopify.com/], Title[301 Moved Permanently], UncommonH
eaders[report-to,nel,server-timing,x-content-type-options,x-permitted-cross-domain-policies,x-download-options,x-shopid,cf-ray,alt-svc], X-XSS-Protection[1; mode=block]
https://shopify.com [301 Moved Permanently] Country[CANADA][CA], HTTPServer[cloudflare], IP[23.227.38.33], RedirectLocation[https://www.shopify.com/], Title[301 Moved Permanently], Uncommon
Headers[report-to,nel,server-timing,x-content-type-options,x-permitted-cross-domain-policies,x-download-options,x-shopid,cf-ray,alt-svc], X-XSS-Protection[1; mode=block]

https://www.shopify.com/ [200 OK] Cookies[_shopify_essential_,_shopify_s,_shopify_y], Country[RESERVED][ZZ], Email[monique@email.com], HTML5, HTTPServer[cloudflare], IP[172.64.145.93], Open
-Graph-Protocol[website][847460188612391], PoweredBy[the], Script[application/ld+json,module,text/javascript], Strict-Transport-Security[max-age=15552000; includeSubDomains; preload], Title
[Shopify: The All-in-One Commerce Platform for Businesses - Shopify], UncommonHeaders[cf-ray,cf-cache-status,server-timing,x-content-type-options,report-to,nel,alt-svc]

(prabindhn_06@vbox)-[~]
$

```

Figure 8:Shopify Fingerprinting

The sensitive information and technology of shopify are collected by using whatweb commands. From the obtained information we can identify such as based country, web server, IP Address, framework and security headers.

- i. Web Server: Cloudflare
- ii. Country: Canada
- iii. Cloudflare IP Address: 23.227.38.33
- iv. Framework: Script[application/ld+json,module,text/javascript]
- v. Security header: X-XSS-Protection[1; mode=block]

e) Wayback Machine review.

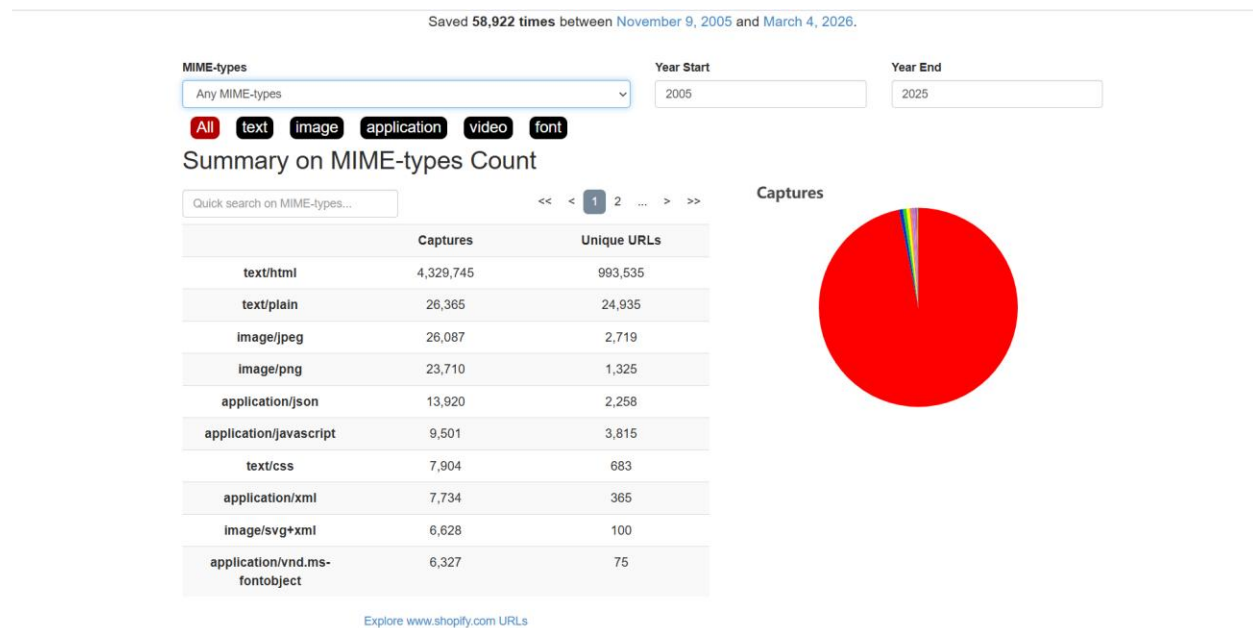


Figure 9: Shopify MIME types

The following table shows the types of files captured of shopify website along with captures and unique URL. The period ranges from November 9, 2005 to March 4, 2026

Captures: Total number of times that files type was archived.

Uniques URL: Number of different URLs containing that file type.

From the table:

Text/html: 4,329,745 captures and 993,535 unique URLs. This represents standard webpage HTML files, which make up the majority of the website.

Text/plain: 26365 captures, usually plain text files.

Image/jpeg and **image/png:** images used on the website.

Application/json: Data used by API or dynamic web services.

Application/javascript: JavaScript files used for website functionality.

Text/css: CSS files responsible for website styling.

Application/xml: Commonly used for sitemap or structured data.

Image/svg+xml: Vector graphics used in the interface.

Application/vnd.ms-fontobject: Font files used for web typography.

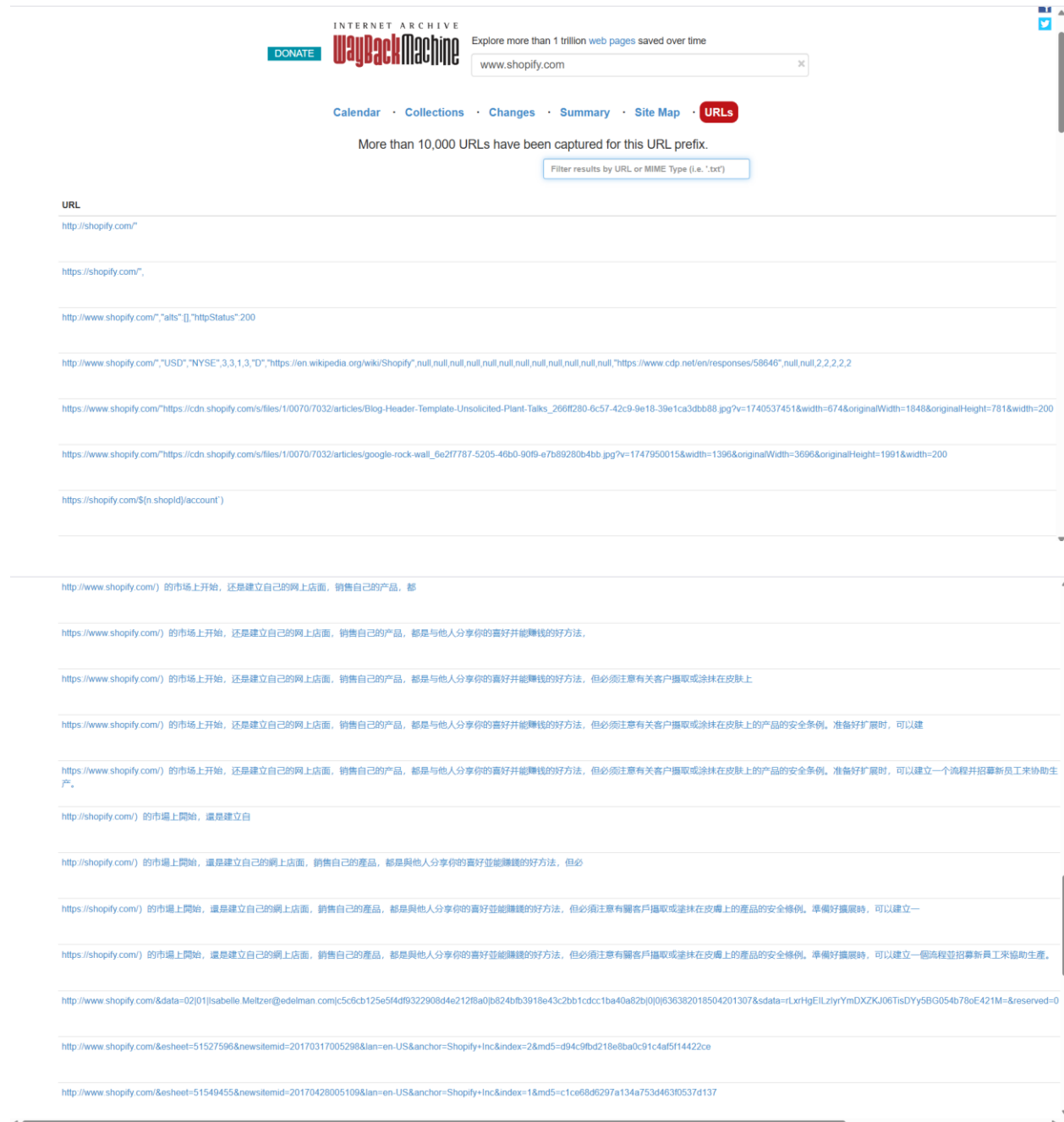


Figure 10: Shopify URL Captures

It period ranges from November 9, 2005 to March 4, 2026. The www.shopify.com path of websites has more than different **10,000 URLs** captured by www.web.archive.org., But it does not display all of them at once due to the large number of result. It discovers old,

latest pages of the website and found removed and hidden URLs. It contains thousands of blog article and Chinese URLs of the shopify website.

f) Email harvesting (theHarvester – passive sources only).

[illegible]

Figure 11: Shopify Harvesting

The theHarvester -d shopify.com -b duckduckgo commands is used for public available email address related to the shopify domain. From the obtained information we can only identify the subdomain of the shopify. Some of them are listed below:

2Fapps.shopify.com

2Fhelp.shopify.com

2Fnews.shopify.com

Privacy.shopify.com

g) Google dorking (site:, filetype:, intitle:, inurl:, wildcard subdomains).

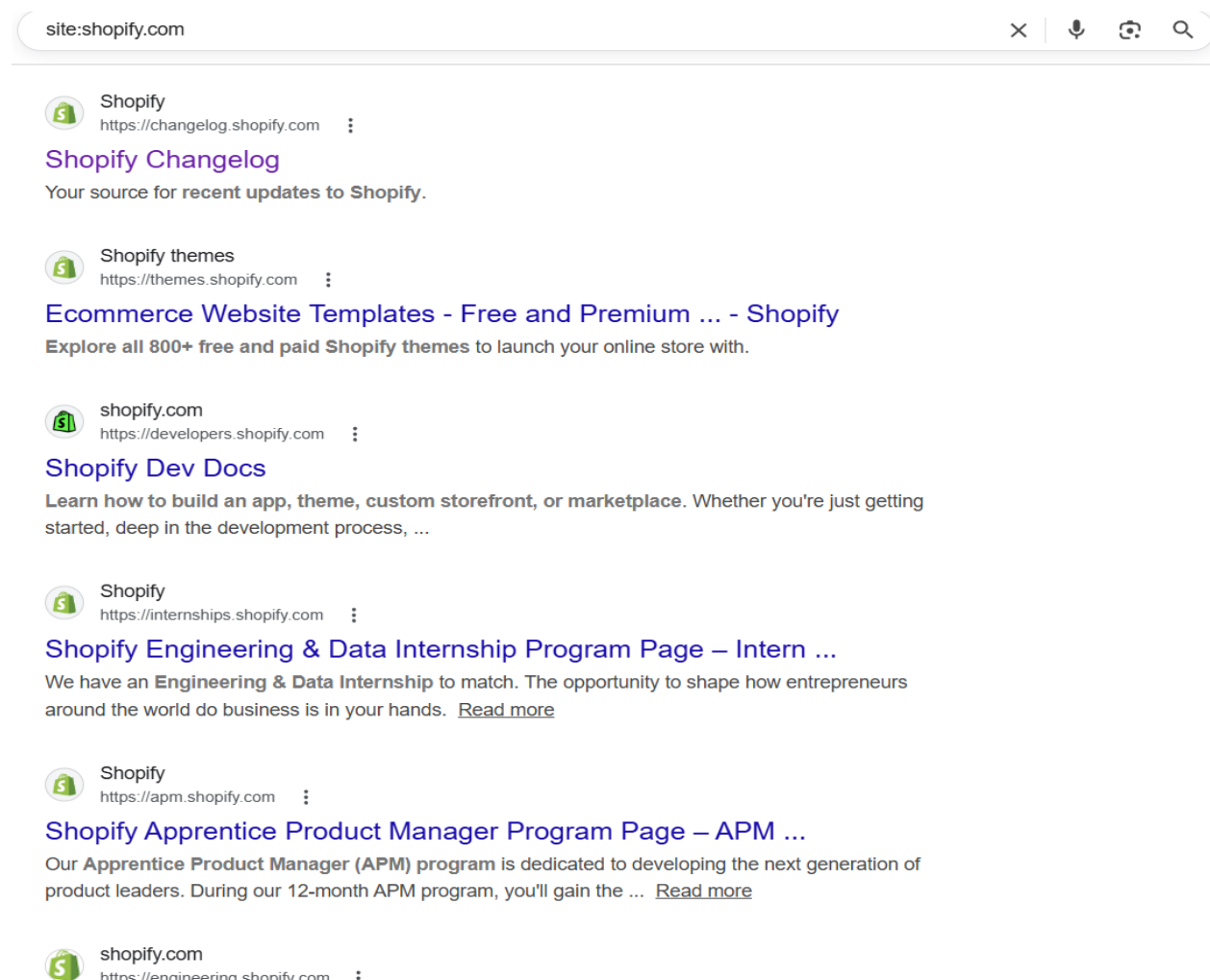


Figure 12: Site: Shopify.com

The site: operator search result only from a specific domain. The site: shopify.com search shows only page that belong with that specific shopify domain. It used for identifying webpages and discover and subpages, directories.

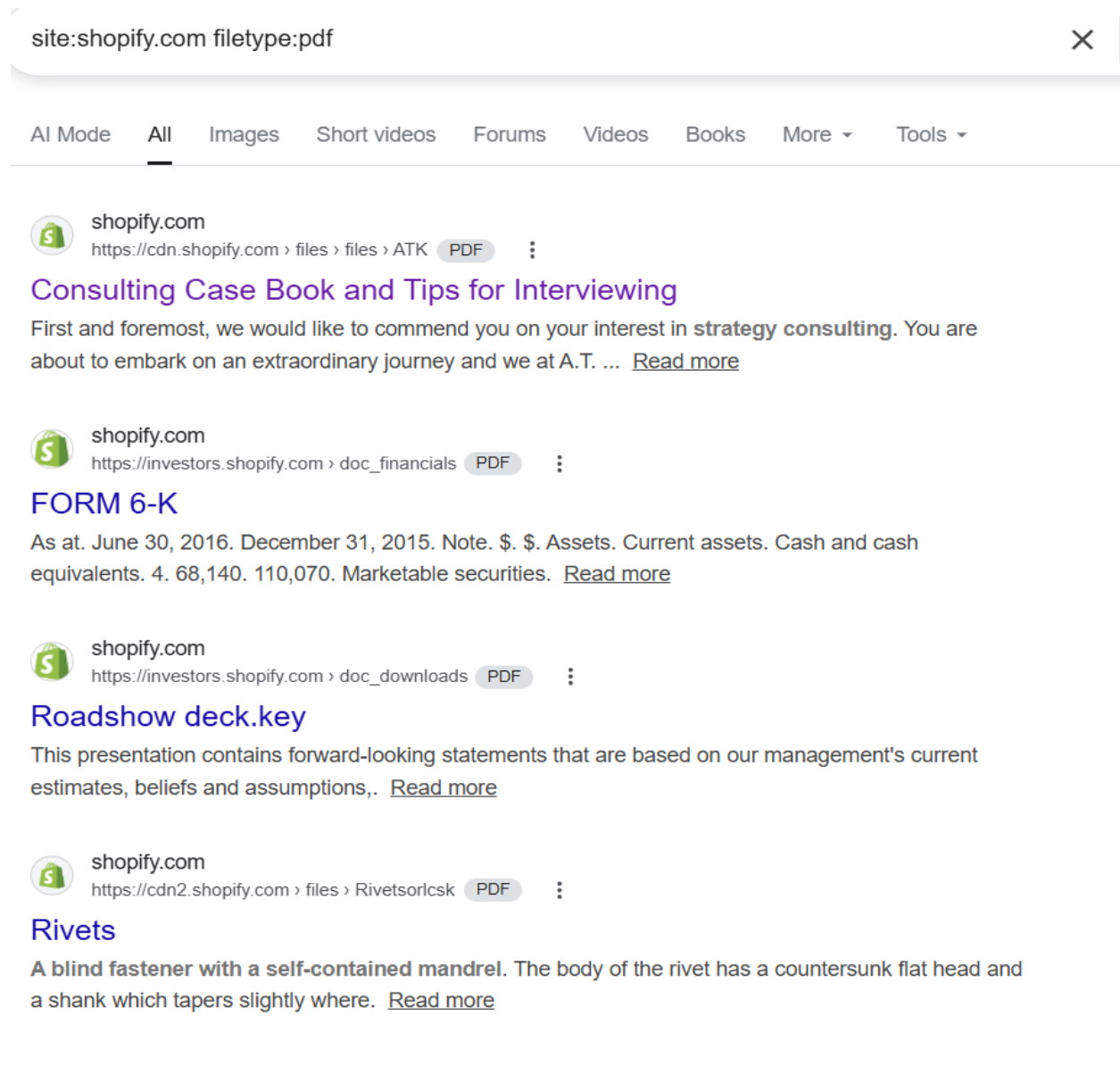


Figure 13: Site:Shopify.com filetype:pdf

The filetype: operator finds specific file formats on a website. The site: shopify.com filetype:pdf search shows pdf files hosted on Shopify. From the obtained search, we can access helpful pdf provided by shopify.com.

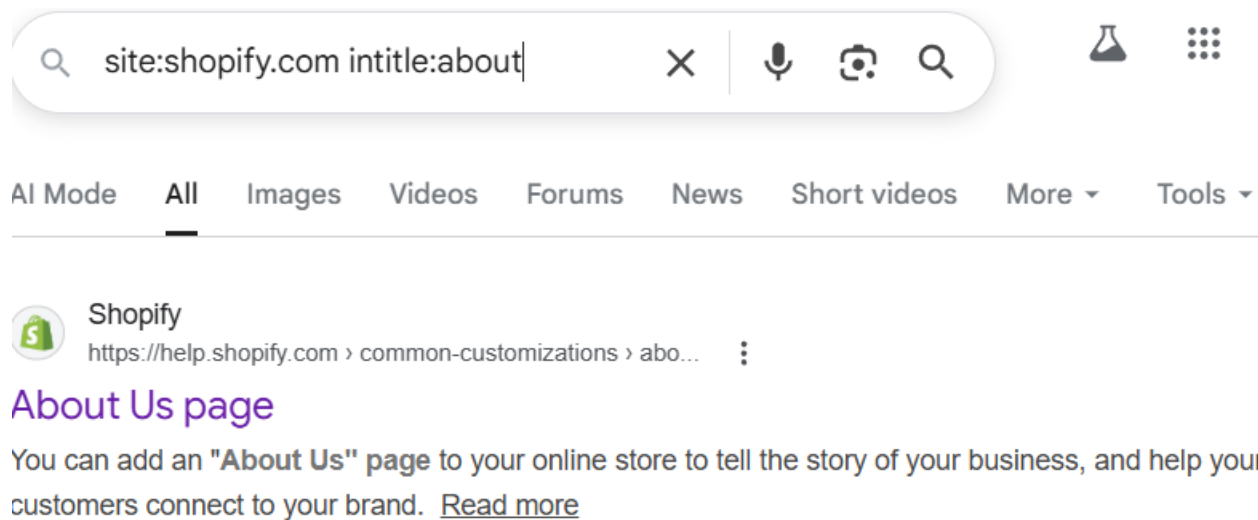


Figure 14: Site:Shopify.com intitle:about

The intitle: operator searches for words in the title of webpage. The site: shopify.com intitle:about shows shopify pages that contain "About us" in the page title. It is used for identifying about us page of the shopify.

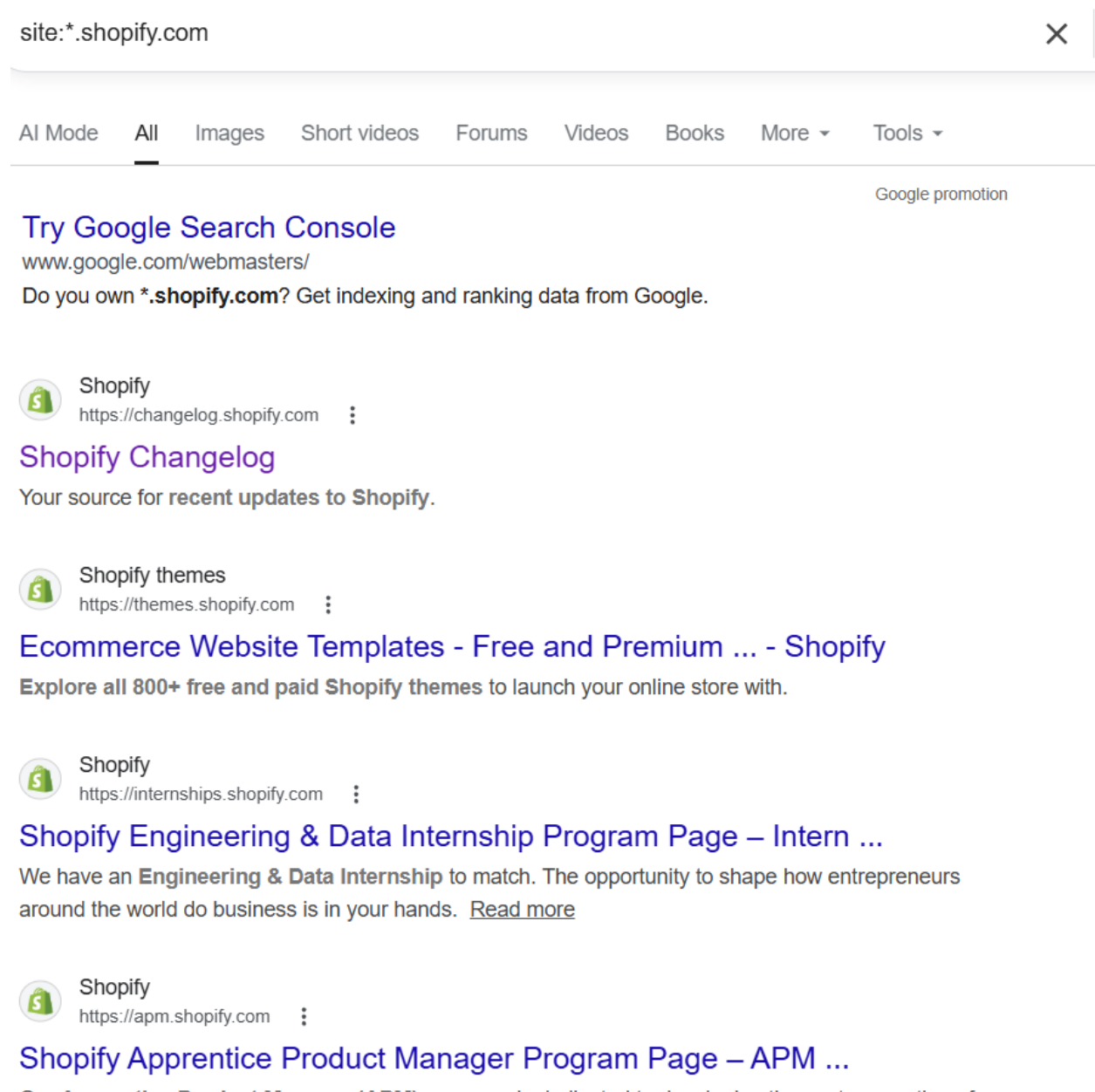


Figure 15: Site: *.Shopify.com

The site: * operator help to discover subdomains of specific domain search. The site: *.shopify.com finds pages from the different shopify subdomain. Some of the subdomains are listed below:

- i. Changelog.shopify.com
- ii. Themes.shopify.com
- iii. Internships.shopify.com

Phase 2 – Active Information Gathering

a) Host discovery (non-intrusive).

```
(prabinpdhn_06@vbox)-[~]
$ ping 23.227.38.33
PING 23.227.38.33 (23.227.38.33) 56(84) bytes of data.
64 bytes from 23.227.38.33: icmp_seq=1 ttl=255 time=11.8 ms
64 bytes from 23.227.38.33: icmp_seq=2 ttl=255 time=17.7 ms
64 bytes from 23.227.38.33: icmp_seq=3 ttl=255 time=14.0 ms
64 bytes from 23.227.38.33: icmp_seq=4 ttl=255 time=11.3 ms
64 bytes from 23.227.38.33: icmp_seq=5 ttl=255 time=12.6 ms
64 bytes from 23.227.38.33: icmp_seq=6 ttl=255 time=10.8 ms
64 bytes from 23.227.38.33: icmp_seq=7 ttl=255 time=12.1 ms
64 bytes from 23.227.38.33: icmp_seq=8 ttl=255 time=12.1 ms
64 bytes from 23.227.38.33: icmp_seq=9 ttl=255 time=16.9 ms
64 bytes from 23.227.38.33: icmp_seq=10 ttl=255 time=10.6 ms
64 bytes from 23.227.38.33: icmp_seq=11 ttl=255 time=10.8 ms
64 bytes from 23.227.38.33: icmp_seq=12 ttl=255 time=12.9 ms
64 bytes from 23.227.38.33: icmp_seq=13 ttl=255 time=11.6 ms
^C
— 23.227.38.33 ping statistics —
13 packets transmitted, 13 received, 0% packet loss, time 12606ms
rtt min/avg/max/mdev = 10.601/12.710/17.686/2.156 ms
```

Figure 16: Host Discovery

The host discovery from the Shopify Ip address was successful. The host is alive and replying to user.

b) Basic Nmap scanning and service/version detection.

```
(prabinpdhn_06@vbox)-[~]
$ nmap -sS shopify.com
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-05 01:50 MST
Nmap scan report for shopify.com (23.227.38.33)
Host is up (0.0080s latency).
rDNS record for 23.227.38.33: checkout.shopify.com
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https
8080/tcp   open  http-proxy
8443/tcp   open  https-alt
```

Figure 17: Port Scanning

The purpose of basic nmap **-sS** port scanning is to identify open ports of the Shopify.
The open ports state of the Shopify is such as 80, 443, 8080 and 8443.

```
(prabindhn_06@vbox)-[~]
$ nmap -sV shopify.com
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-05 02:01 MST
Nmap scan report for shopify.com (23.227.38.33)
Host is up (0.0083s latency).
rDNS record for 23.227.38.33: checkout.shopify.com
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http    Cloudflare http proxy
443/tcp   open  ssl/http Cloudflare http proxy
8080/tcp  open  http    Cloudflare http proxy
8443/tcp  open  ssl/http Cloudflare http proxy

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.49 seconds
```

Figure 18: Service Detection

The nmap command **-sV** shows that the open ports on Shopify are running Cloudflare services.

c) Operating system detection.

```
(prabindhn_06@vbox)-[~]
$ nmap -O shopify.com
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-05 02:13 MST
Nmap scan report for shopify.com (23.227.38.33)
Host is up (0.0069s latency).
rDNS record for 23.227.38.33: checkout.shopify.com
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https
8080/tcp  open  http-proxy
8443/tcp  open  https-alt
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: bridge|VoIP adapter|general purpose
Running (JUST GUESSING): Oracle Virtualbox (98%), Slirp (98%), AT&T embedded (95%), QEMU (94%)
OS CPE: cpe:/o:oracle:virtualbox cpe:/a:danny_gasparovski:slirp cpe:/a:qemu:qemu
Aggressive OS guesses: Oracle Virtualbox Slirp NAT bridge (98%), AT&T BGW210 voice gateway (95%), QEMU user mode network gateway (94%)
No exact OS matches for host (test conditions non-ideal).

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.14 seconds
```

Figure 19: OS System Detection

The nmap **-O** commands for the detecting OS system show 98% probability of Oracle VirtualBox Slirp, 95% probability of AT&T embedded and 94% probability of QEMU.

d) WAF detection.

```
(prabinpdhn_06@vbox)-[~]
$ wafw00f shopify.com

      ?      (      .      )      .      "
      (      )      )      .      (      '
      .;      '      ((      "      ;      (      (      ;      "      ")
      -      .      ,      -      .      )      (      .      )      -      '      )      (      .      ..      (      '      )
      |      |      |      |      |      |      |      |      |      |      |      |      |      |      |      |      |
      ~ WAFW00F : v2.3.1 ~
      ~ Sniffing Web Application Firewalls since 2014 ~

[*] Checking https://shopify.com
[+] The site https://shopify.com is behind Cloudflare (Cloudflare Inc.) WAF.
[~] Number of requests: 2
```

Figure 20: WAF Detection

The **wafw00f** commands detected Sniffing Web Application Firewalls (WAF) protecting the Shopify, since 2014.

e) DNS zone transfer attempt (if permitted).

```
(prabinpdhn_06@vbox)-[~]
$ host -l shopify.com ns1.shopify.com
;; Connection to 23.227.38.33#53(23.227.38.33) for shopify.com failed: timed out.
;; no servers could be reached
;; Connection to 23.227.38.33#53(23.227.38.33) for shopify.com failed: timed out.
;; no servers could be reached
```

Figure 21: DNS Transfer Attempt

The DNS zone transfer request for shopify.com is not respond by the server and Shopify DNS Server blocks unauthorized zone transfers with the message no servers could be reached.

Phase 3 – Analysis & Attack Surface Mapping

a) Asset inventory (domains, subdomains, IPs, open ports).

```
(prabindhn_06@vbox)-[~]  
$ nslookup shopify.com  
Server:          10.0.2.3  
Address:         10.0.2.3#53  
  
Non-authoritative answer:  
Name:   shopify.com  
Address: 23.227.38.33
```

```
(prabindhn_06@vbox)-[~]  
$ subfinder -d shopify.com  
  
projectdiscovery.io  
  
[INF] Current subfinder version v2.6.0 (outdated)  
[INF] Loading provider config from the default location: /home/prabindhn_06/.config/subfinder/provider-config.yaml  
[INF] Enumerating subdomains for shopify.com  
  
snapify.shopify.com  
afterhours.shopify.com  
50ae1a-3r.shopify.com  
96.nat.ash.shopify.com  
accnts.shopify.com  
nexus.shopify.com  
h.ssl.shopify.com  
webinar-sept-30.shopify.com  
23-227-38-31.shopify.com  
4apps.shopify.com  
exchange-help.shopify.com  
toronto.shopify.com  
stevenessus-test.ec2.shopify.com  
tashboard.shopify.com  
23-227-38-29.shopify.com  
23-227-38-40.shopify.com  
upcoming12.shopify.com  
110.nat.ash.shopify.com  
cdn.shopify.com  
colourdecoded.shopify.com  
sourcing-supplier.shopify.com  
102.nat.ash.shopify.com  
ec1.shopify.com  
flwca.shopify.com  
sugarpack.shopify.com  
projectboard.shopify.com  
tableau-dev.data.shopify.com  
lifehacks.shopify.com  
tmt.shopify.com  
252fcdn.shopify.com  
amazon.shopify.com  
next.shopify.com  
in.shopify.com  
icinga.chi2.shopify.com
```

Figure 22: Finding Ip Address of domain and Shopify Subdomain sites

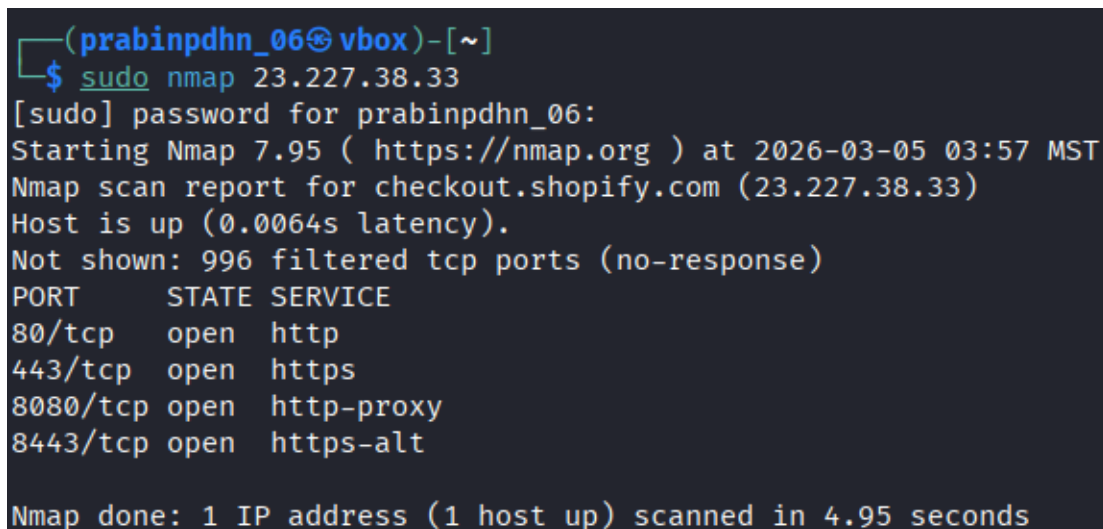
The nslookup command finds the ip address associated with the Shopify. From the given we obtained information such as Shopify Ip address 23.277.38.33 and server ip address 10.0.2.3

The subfinder -d shopify.com commands discovered 435 subdomains for shopify.com. The example of the detected such subdomains are:

i. Amazon.shopify.com

ii. Next.shopify.com

iii. In.shopify.com



```
(prabindhn_06@vbox)-[~]
$ sudo nmap 23.227.38.33
[sudo] password for prabindhn_06:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-05 03:57 MST
Nmap scan report for checkout.shopify.com (23.227.38.33)
Host is up (0.0064s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
443/tcp   open  https
8080/tcp  open  http-proxy
8443/tcp  open  https-alt

Nmap done: 1 IP address (1 host up) scanned in 4.95 seconds
```

Figure 23: Port Scanning in the target IP Address

The sudo nmap command with the target ip addresses 23.227.38.33 shows open ports of service and open port includes 80 for http, 443 for https, 8080 for http-proxy and 8443 for https-alt.

b) Identify potential attack surface areas.

Ans: The identified potential attack surface areas are:

i. Multiple subdomains: Shopify Subdomains areas increase the number of entries points in the website that attacker can potentially target.

ii. Open Web Ports: Open web ports such as 80 and 443 allow public access to web service, which expands the external attack surface.

iii. Wayback Machine Captured URLs: The wayback machine captured more than 10,000 URLs links including old blogs articles and thousands of Chinese URLs from the Shopify website. These links may contain any loopholes in the websites that attacker can potentially exploit.

c) Explain why findings may present risk.

Ans: From this reconnaissance phase, it is noted that there are exposed assets such as the domain, associated IP address, open web ports, and multiple subdomains. This indicates that ports such as 80 and 443 enable public access to web services, thus increasing the attack surface. Moreover, the presence of multiple subdomains could imply additional avenues that require security measures. Technology fingerprinting showed that Shopify utilizes a Content Delivery Network, denoted by a Cloudflare firewall, which provides security against common web-based attacks and helps to mask infrastructure. This indicates that attackers could target attempts to evade these security measures. DNS records such as an A record, which resolves to 23.227.38.33, confirm that the domain maps to a server. Poorly managed DNS records could imply additional attack surfaces such as subdomains. Additionally, historical data such as information obtained from the Wayback Machine and existing files such as robots.txt and sitemap.xml could imply accessible resources, which could be used by attackers during reconnaissance for potential vulnerabilities. It is noted that Shopify has robust security measures, but the identified attack surfaces require constant monitoring and security to ensure robust security.

Conclusion:

This assignment, which was based on a VDP (Vulnerability Disclosure Program) or Bug Bounty scenario, was focused on the Shopify e-commerce platform to undertake a structured information gathering and analysis exercise. The results of the passive reconnaissance included domain, subdomain, IP, DNS, and technology stack, including CDN and WAF. The results of the active information gathering included open ports, including 80, 443, 8080, and 8443, and the presence of a Cloudflare Web Application Firewall. The results of the attack surface mapping included potential exposure points, including web services and subdomains. The results of the reconnaissance also included historical information, including the results of using the Wayback Machine, which gave us insight into the history of Shopify's web pages and resources, which could still pose a potential risk if misconfigured.

The detection of WAF using wafw00f also identified the presence of Cloudflare, which has been confirmed by the historical analysis that has identified the presence of Web Application Firewall protection from 2014 onwards in Shopify. This has identified that, despite the presence of strong security controls in Shopify, it is imperative to understand the historical content, endpoints, and security controls in order to effectively map the attack surface of the application in the context of the Bug Bounty program.